МІНІСТЕРСТВО ОСВІТИ І НАУКИ УКРАЇНИ

НАЦІОНАЛЬНИЙ ТЕХНІЧНИЙ УНІВЕРСИТЕТ УКРАЇНИ
«КИЇВСЬКИЙ ПОЛІТЕХНІЧНИЙ ІНСТИТУТ імені ІГОРЯ СІКОРСЬКОГО»

Навчально-науковий фізико-технічний інститут

Кафедра інформаційної безпеки

ЗВІТ

з дисципліни «Кіберзахист об’єктів критичної інфраструктури»

Лабораторна робота № 2. Оцінювання вразливостей об’єкта критичної інфраструктури на основі показника CVSS

Варіант 4

Виконав: Вовкотруб Олександр Віталійович
Група: ФБ-61мн

Перевірив: Войцеховський А. В.

Київ 2026

Зміст

1 Мета роботи **2**

2 Постановка задачі **2**

3 Теоретичні відомості **2**

3.1 Метрики CVSS v3.1 2

3.2 Об’єкт оцінювання 3

4 Хід виконання **4**

4.1 Методика 4

4.2 Опис атак 4

CVE-2020-11896: Ripple20, стек TCP/IP Treck 4

CVE-2021-36260: ін’єкція команд у вебсервері камер Hikvision 4

CVE-2022-38465: ключ захисту ПЛК Siemens SIMATIC S7-1200/1500 5

CVE-2019-10953: відмова в обслуговуванні ПЛК через мережевий флуд 5

CVE-2019-16336: SweynTooth, BLE у мікроконтролерах Cypress PSoC 4 5

4.3 Таблиця метрик 6

4.4 Обчислення за допомогою калькулятора FIRST 7

5 Результати **10**

6 Аналіз рівня небезпечності **10**

7 Рекомендації **11**

8 Відповіді на контрольні питання **12**

9 Висновки **13**

10 Перелік джерел **13**

Додаток А. Калькулятор CVSS 3.1 (`cvss31.py`) **14**

Додаток Б. Розрахунки та побудова (`solution.py`) **17**

1 Мета роботи

Ознайомитися з моделлю загроз, типовою для об'єктів критичної інфраструктури (OKI), на прикладі промислового інтернету речей (IIoT). Опанувати методику розрахунку показника CVSS за Common Vulnerability Scoring System v3.1 на прикладі вразливостей кінцевих пристроїв OKI.

2 Постановка задачі

Номер у списку 3, отже варіант $3 \bmod 10 + 1 = 4$: **експлуатація вразливостей програмного забезпечення (або прошивки) кінцевих пристроїв IIoT**.

Завдання:

1. зібрати дані про типові атаки цього класу на OKI, проаналізувати можливі шляхи їх здійснення, коротко описати атаки та заповнити таблицю метрик для конкретних випадків;
2. за допомогою калькулятора фреймворку обчислити значення CVSS;
3. зробити висновки про рівень небезпечності для заданого об'єкта;
4. надати рекомендації щодо усунення проблем на OKI.

Для конкретики розглянуто п'ять реальних вразливостей із бази NVD, що охоплюють різні типи кінцевих пристроїв IIoT і всі практично важливі вектори атаки: мережевий (N), суміжний (A) і локальний (L).

3 Теоретичні відомості

3.1 Метрики CVSS v3.1

CVSS оцінює **серйозність** вразливості числом від 0 до 10. Метрики поділено на три групи:

- **базові** (Base) описують властивості самої вразливості, незмінні в часі та однакові для всіх середовищ: вектор (AV), складність (AC), потрібні привілеї (PR), взаємодія з користувачем (UI), область впливу (S) і вплив на конфіденційність, цілісність, доступність (C, I, A);
- **часові** (Temporal) змінюються з часом: зрілість експлойта (E), рівень виправлення (RL), достовірність звіту (RC);
- **середовищні** (Environmental) налаштовують оцінку під конкретну організацію: вимоги до конфіденційності, цілісності, доступності активу (CR, IR, AR) та модифіковані базові метрики (MAV, MAC, …), що враховують наявні засоби захисту.

Базова оцінка обчислюється так. Спочатку знаходиться базовий показник впливу

$$ISS = 1 - (1 - C)(1 - I)(1 - A), \tag{3.1}$$

де $C, I, A \in \{0{,}56;\ 0{,}22;\ 0\}$ для значень High, Low, None. Далі обчислюються підоцінки впливу та експлуатованості:

$$Impact = \begin{cases} 6{,}42 \cdot ISS, & S = U, \\ 7{,}52\,(ISS - 0{,}029) - 3{,}25\,(ISS - 0{,}02)^{15}, & S = C, \end{cases} \tag{3.2}$$

$$Exploitability = 8{,}22 \cdot AV \cdot AC \cdot PR \cdot UI. \tag{3.3}$$

Базова оцінка дорівнює Roundup(min$(Impact + Exploitability,\ 10)$) для $S = U$ і Roundup(min$(1{,}08\,(Impact + Exploitability),\ 10)$) для $S = C$ (нуль, якщо $Impact \leq 0$). Часова оцінка дорівнює Roundup$(Base \cdot E \cdot RL \cdot RC)$. Середовищна оцінка обчислюється за тими самими формулами з модифікованими метриками, де вплив зважується вимогами $CR, IR, AR \in \{1{,}5;\ 1;\ 0{,}5\}$ (High, Medium, Low). Roundup означає округлення вгору до однієї десяткової цифри.

Якісна шкала: 0 None, 0,1…3,9 Low, 4,0…6,9 Medium, 7,0…8,9 High, 9,0…10,0 Critical.

3.2 Об’єкт оцінювання

Як ОКІ взято умовний **міський водоканал** (сектор водопостачання за Законом України «Про критичну інфраструктуру»). Архітектура відповідає моделі Purdue: рівні 0…1 (датчики, виконавчі механізми, ПЛК насосних станцій), рівень 2 (SCADA, HMI, інженерна станція), рівень 3 (Historian), DMZ і корпоративна мережа. Для такого об’єкта головне значення мають **доступність** і **цілісність** технологічного процесу: зупинка насосів або хибні команди безпосередньо загрожують водопостачанню міста. Конфіденційність важлива переважно для ключів, паролів і конфігурацій.

Вимоги до активів, використані в середовищних метриках, наведено в табл. 3.1.

Таблиця 3.1. Активи водоканалу та вимоги до них

Актив	CR	IR	AR
Мережеві карти ДБЖ, шлюзи RS-485/Ethernet	L	H	H
IP-камери охорони периметра	H	M	M
ПЛК керування насосами (Siemens S7-1200/1500)	H	H	H
ПЛК різних виробників (вразливість до флуду)	L	M	H
Бездротові BLE-датчики тиску й рівня	L	L	M

4 Хід виконання

4.1 Методика

Для кожної вразливості:

1. базовий вектор узято з первинної оцінки NVD (файли `data/CVE-*.json`, отримані через NVD API 2.0);
2. часові метрики визначено за відкритими даними про експлойти та виправлення (обґрунтування в п. 4.2);
3. середовищну оцінку обчислено у двох станах: **«як є»** (лише вимоги CR, IR, AR з табл. 3.1) та **«після заходів»** (модифікована метрика, що відображає компенсуючий захід, поки виправлення ще не встановлено).

Оцінки обчислено двома незалежними способами: власним калькулятором `cvss31.py`, написаним за специфікацією FIRST [1], і офіційним калькулятором FIRST [2]. Скрипт `solution.py` порівнює результати автоматично; усі 20 оцінок (4 оцінки для 5 вразливостей) збіглися, а базові також збіглися з NVD.

4.2 Опис атак

CVE-2020-11896: Ripple20, стек TCP/IP Treck

Ripple20 означає групу з 19 вразливостей бібліотеки TCP/IP компанії Treck, опубліковану дослідниками JSOF у червні 2020 року [3]. Бібліотеку десятиліттями вбудовували у свої прошивки сотні виробників: ДБЖ (зокрема мережеві карти APC), промислові шлюзи Digi, медичне обладнання, принтери, компоненти систем керування. CVE-2020-11896 пов'язана з обробкою фрагментованих пакетів IPv4-in-IPv4 (тунелювання): неправильна перевірка довжини призводить до переповнення буфера (CWE-119) і до віддаленого виконання коду **одним мережевим пакетом без автентифікації**. Область впливу змінюється ($S = C$), бо скомпрометований мережевий стек дає контроль над усім пристроєм і його функцією. Шлях атаки: доступ до сегмента, де є пристрій (або до інтернету, якщо пристрій виставлено назовні), і надсилання спеціального пакета. Головна проблема для OKI полягає в ланцюжку постачання: власник часто не знає, що в його обладнанні є бібліотека Treck.

Часові метрики: E:P (JSOF опублікували технічний звіт з демонстрацією експлуатації на реальному пристрої, але загальнодоступного бойового експлойта немає), RL:O (Treck випустила версію 6.0.1.66, виробники пристроїв випускали оновлення прошивок), RC:C.

CVE-2021-36260: ін'єкція команд у вебсервері камер Hikvision

Вбудований вебсервер багатьох IP-камер і відеореєстраторів Hikvision [9] недостатньо перевіряє вхідні дані, тому спеціально сформований HTTP-запит приводить до виконання команд ОС (CWE-78) **без автентифікації**. Вразливість внесено до каталогу CISA KEV (активно

експлуатується); її за публічними повідомленнями [9], вразливість масово експлуатувалася ботнетами (зокрема Mirai-подібними). На OKI камери охорони периметра часто підключено до тієї ж мережі, що й інше обладнання, тому зламана камера стає плацдармом для руху всередину мережі та розвідки, а також дозволяє «осліпити» фізичну охорону. Шлях атаки: доступ до вебінтерфейсу камери (порт 80/443, часто проброшений назовні для віддаленого перегляду).

Часові метрики: E:H (масова експлуатація, готові інструменти), RL:O (оновлення прошивки від виробника), RC:C.

CVE-2022-38465: ключ захисту ПЛК Siemens SIMATIC S7-1200/1500

Прошивки ПЛК SIMATIC S7-1200 і S7-1500 використовували **глобальний приватний ключ**, однаковий для всієї лінійки продуктів, захищений недостатньо (CWE-522). Згідно з бюлетенем Siemens [4], маючи доступ до пам'яті одного контролера, можна витягти цей ключ [4]. Маючи його, зловмисник розшифровує захищений обмін між інженерною станцією і **будь-яким** ПЛК цієї лінійки, отримує паролі та конфігурацію, а також може підробляти комунікацію. NVD оцінює вектор як локальний (AV:L, PR:L), а Siemens як виробник оцінює вразливість суворіше: AV:L/PR:N/S:C, базова оцінка 9,3. Розбіжність показує, що вибір області впливу (S) суттєво впливає на результат: один витягнутий ключ ставить під загрозу всі інші контролери. Siemens усунула проблему оновленням прошивки (бюлетень SSA-568427 [4]).

Часові метрики: E:P (атаку продемонстровано дослідниками, вільного інструмента немає), RL:O, RC:C.

CVE-2019-10953: відмова в обслуговуванні ПЛК через мережевий флуд

Згідно з бюлетенем CISA ICSA-19-106-03 [8], ПЛК кількох виробників (ABB, Phoenix Contact, Schneider Electric, Siemens, WAGO) перестають нормально працювати під потоком мережевих пакетів (CWE-400, CWE-770): ресурси процесора і мережевого стеку вичерпуються, страждає обмін даними з SCADA і виконання циклу керування. Атака тривіальна (стандартні засоби генерації трафіку), не потребує автентифікації і порушує лише доступність. Для водоканалу саме доступність є критичною вимогою, тому в середовищній оцінці ця вразливість стає однією з найнебезпечніших.

Часові метрики: E:H (атака виконується загальнодоступними засобами), RL:W (основні рекомендації виробників зводяться до обмеження трафіку і сегментації мережі, тобто до обхідних заходів), RC:C.

CVE-2019-16336: SweynTooth, BLE у мікроконтролерах Cypress PSoC 4

SweynTooth означає сімейство вразливостей реалізацій Bluetooth Low Energy у SDK кількох виробників мікросхем, опубліковане дослідниками Singapore University of Technology and Design у 2020 році [5]. CVE-2019-16336 у стеку BLE Cypress PSoC 4 полягає в тому, що кадр канального рівня з довжиною корисного навантаження, більшою за дозволену, приводить до

збою (CWE-120) і зупинки пристрою. Атакувальник має бути в радіусі дії радіоканалу (AV:A), автентифікація не потрібна. На ОКІ такі мікросхеми використовуються в бездротових датчиках і портативних пристроях налаштування; їх збій означає втрату телеметрії.

Часові метрики: E:F (дослідники опублікували робочі PoC-скрипти для доступного BLE-адаптера), RL:O (оновлення компонента BLE від Cypress), RC:C.

4.3 Таблиця метрик

Значення метрик для всіх п’яти випадків наведено в табл. 4.1.

Таблиця 4.1. Метрики CVSS v3.1 для обраних вразливостей

Метрика	CVE-2020-11896	CVE-2021-36260	CVE-2022-38465	CVE-2019-10953	CVE-2019-16336
Пристрій	шлюзи, ДБЖ	IP-камера	ПЛК Siemens	ПЛК	BLE-датчик
CWE	119	78	522	400, 770	120
AV	N	N	L	N	A
AC	L	L	L	L	L
PR	N	N	L	N	N
UI	N	N	N	N	N
S	C	U	U	U	U
C / I / A	H / H / H	H / H / H	H / H / H	N / N / H	N / N / H
Impact	6,05	5,87	5,87	3,60	3,60
Exploitability	3,89	3,89	1,83	3,89	2,84
Базова оцінка	**10,0**	**9,8**	**7,8**	**7,5**	**6,5**
E / RL / RC	P / O / C	H / O / C	P / O / C	H / W / C	F / O / C
Часова оцінка	**9,0**	**9,4**	**7,0**	**7,3**	**6,0**
CR / IR / AR	L / H / H	H / M / M	H / H / H	L / M / H	L / L / M
Середовищна, як є	**9,0**	**9,4**	**7,0**	**9,1**	**6,0**
Компенсуючий захід	MAV:A	MAV:A	MPR:H	MAV:A	MAC:H
Після заходів	**8,7**	**8,4**	**6,0**	**8,1**	**4,9**

Повні рядки-вектори (стан «після заходів»):

```
CVE-2020-11896  CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H/E:P/RL:O/RC:C/CR:L/IR:H/AR:H/MAV:A
CVE-2021-36260  CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:H/RL:O/RC:C/CR:H/IR:M/AR:M/MAV:A
CVE-2022-38465  CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H/E:P/RL:O/RC:C/CR:H/IR:H/AR:H/MPR:H
CVE-2019-10953  CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:H/RL:W/RC:C/CR:L/IR:M/AR:H/MAV:A
CVE-2019-16336  CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:F/RL:O/RC:C/CR:L/IR:L/AR:M/MAC:H
```

Компенсуючі заходи: **MAV:A** означає, що пристрій перенесено в ізольований сегмент ОТ-мережі без доступу з інтернету та корпоративної мережі (атакувальник мусить спершу

потрапити в цей сегмент); **MPR:H** означає, що доступ до інженерної станції і ПЛК мають лише адміністратори з MFA; **MAC:H** означає, що BLE-датчики розміщено на охоронюваній території з контролем радіоефіру, тож атакувальнику потрібно подолати додаткові умови.

4.4 Обчислення за допомогою калькулятора FIRST

Знімки офіційного калькулятора FIRST для стану «як є» наведено на рис. 4.1…4.5. На кожному знімку видно вибрані значення базових і часових метрик, повний рядок-вектор, а також базову, часову та середовищну оцінки.

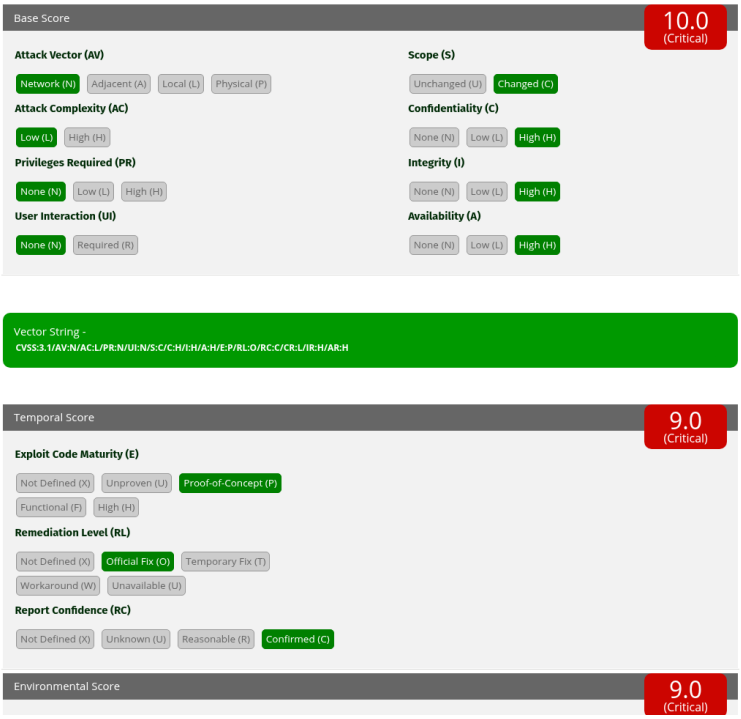


Рисунок 4.1. Калькулятор FIRST, CVE-2020-11896 (Ripple20)

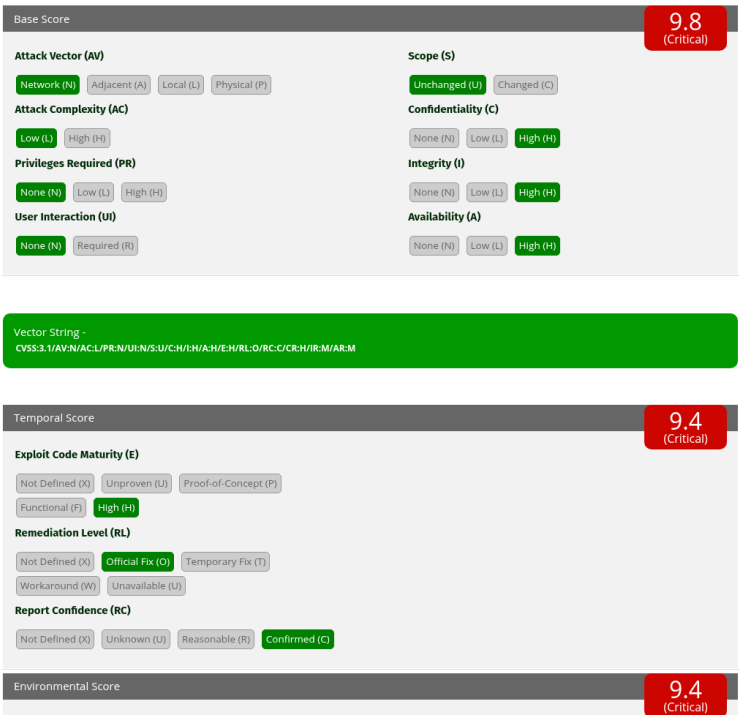


Рисунок 4.2. Калькулятор FIRST, CVE-2021-36260 (Hikvision)

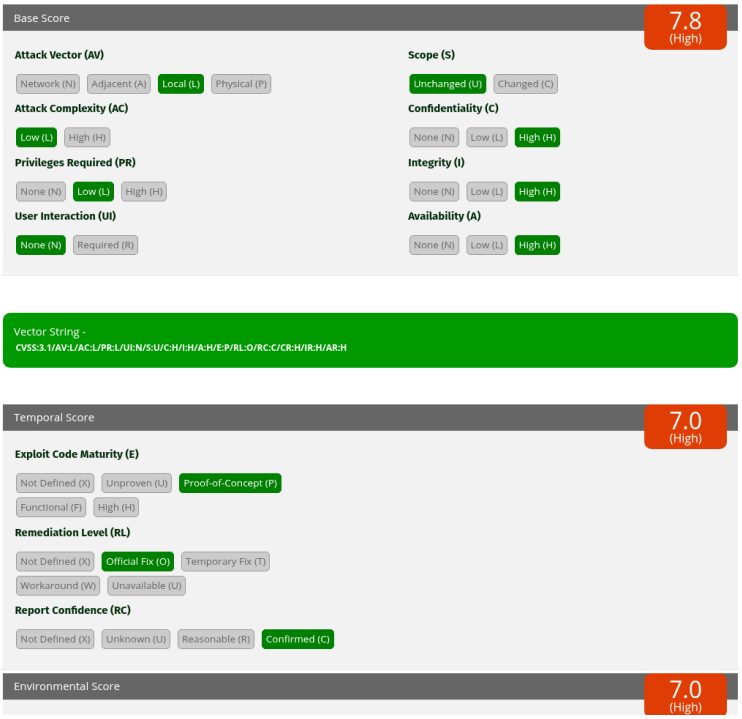


Рисунок 4.3. Калькулятор FIRST, CVE-2022-38465 (Siemens S7-1200/1500)

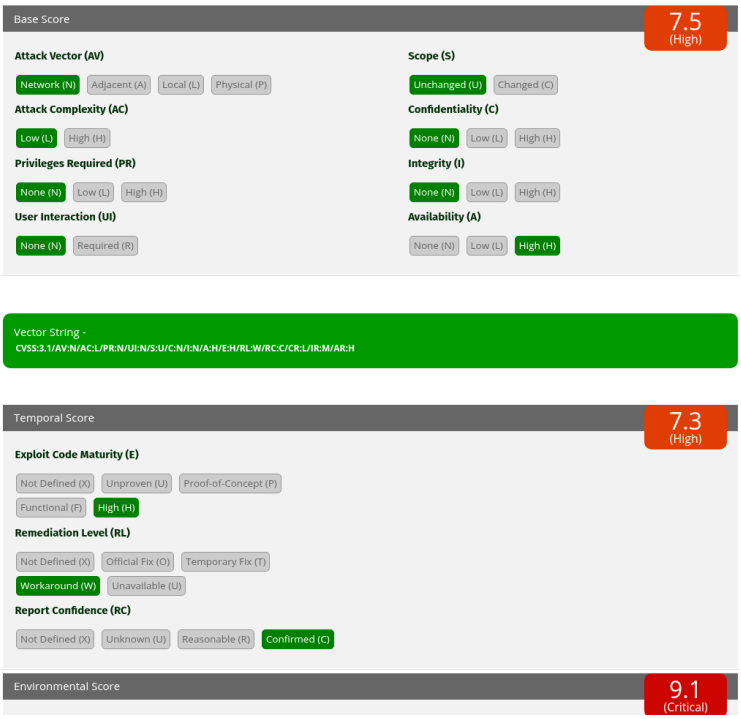


Рисунок 4.4. Калькулятор FIRST, CVE-2019-10953 (DoS ПЛК)

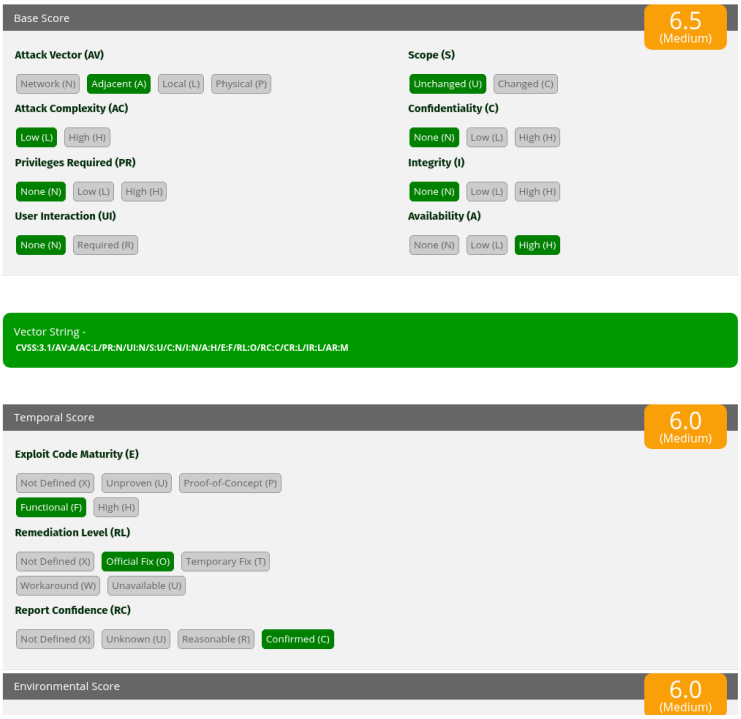


Рисунок 4.5. Калькулятор FIRST, CVE-2019-16336 (SweynTooth)

Приклад ручного обчислення для CVE-2019-10953. Оскільки $C = I = 0$, а $A = 0{,}56$, маємо $ISS = 0{,}56$ і $Impact = 6{,}42 \cdot 0{,}56 = 3{,}595$, $Exploitability = 8{,}22 \cdot 0{,}85 \cdot 0{,}77 \cdot 0{,}85 \cdot 0{,}85 = 3{,}887$, базова оцінка $\text{Roundup}(7{,}482) = 7{,}5$. Часова оцінка $\text{Roundup}(7{,}5 \cdot 1 \cdot 0{,}97 \cdot 1) = 7{,}3$. У середовищній оцінці $AR = 1{,}5$, тому $MISS = \min(1{,}5 \cdot 0{,}56;\ 0{,}915) = 0{,}84$, $MImpact = 6{,}42 \cdot 0{,}84 = 5{,}393$. Тоді $\text{Roundup}(\min(5{,}393 + 3{,}887;\ 10)) = \text{Roundup}(9{,}280) = 9{,}3$, і середовищна

оцінка дорівнює $\mathrm{Roundup}(9{,}3 \cdot 1 \cdot 0{,}97 \cdot 1) = \mathrm{Roundup}(9{,}021) = 9{,}1$, що збігається з калькулятором FIRST (рис. 4.4).

5 Результати

Зведені оцінки показано на рис. 5.1 і в табл. 5.1.

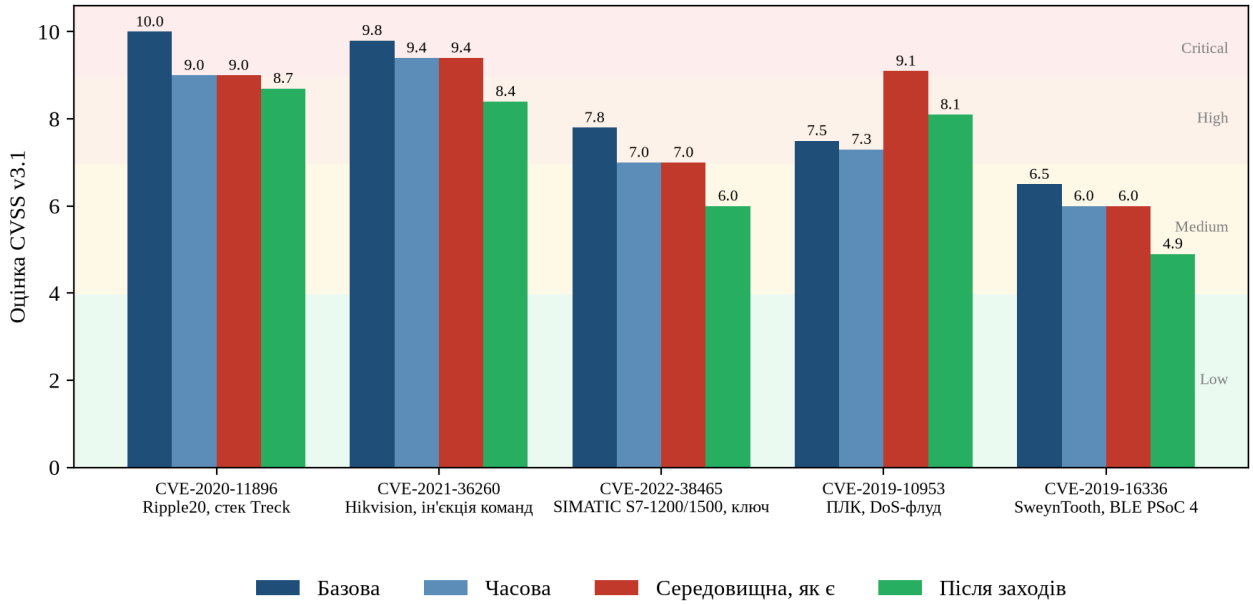


Рисунок 5.1. Оцінки CVSS v3.1: базова, часова, середовищна для водоканалу та після компенсуючих заходів

Таблиця 5.1. Рівні небезпечності

Вразливість	Базова	Середовищна, як є	Після заходів
CVE-2020-11896, Ripple20	10,0 Critical	9,0 Critical	8,7 High
CVE-2021-36260, Hikvision	9,8 Critical	9,4 Critical	8,4 High
CVE-2022-38465, Siemens S7	7,8 High	7,0 High	6,0 Medium
CVE-2019-10953, DoS ПЛК	7,5 High	**9,1 Critical**	8,1 High
CVE-2019-16336, SweynTooth	6,5 Medium	6,0 Medium	4,9 Medium

6 Аналіз рівня небезпечності

Загальний рівень. Чотири з п’яти вразливостей мають оцінку High або Critical у середовищі водоканалу. Отже, експлуатація вразливостей ПЗ і прошивок кінцевих пристроїв IIoT є загрозою **критичного** рівня для цього об’єкта. Спільні риси найнебезпечніших випадків: мережевий вектор, відсутність автентифікації і відсутність взаємодії з користувачем, тобто

атаку можна автоматизувати, що й спостерігалося для камер Hikvision (масова експлуатація, каталог KEV).

Вплив середовища. Середовищні метрики суттєво змінюють пріоритети. DoS-вразливість ПЛК (CVE-2019-10953) має найнижчу базову оцінку серед мережевих (7,5), але для водоканалу, де доступність насосних станцій має найвищий пріоритет ($AR = H$), її оцінка зростає до **9,1 Critical**. Чутливість до цієї однієї метрики перевірено прямо: за тієї самої вразливості з середньою вимогою до доступності ($AR = M$, як для звичайного IT-активу) середовищна оцінка лишається 7,3 High. Тобто різниця між «рядовою» та критичною вразливістю тут закладена в одну вимогу до доступності, і саме її треба обґрунтовувати найретельніше. Натомість для Ripple20 низька вимога до конфіденційності шлюзів ($CR = L$) разом зі зрілістю експлойта E:P знижує оцінку з 10,0 до 9,0. Ранжування лише за базовою оцінкою для OKI є хибним, бо ігнорує фізичні наслідки порушення доступності.

Вплив часу. Наявність активної експлуатації (KEV, E:H) робить камери Hikvision першочерговою ціллю, незважаючи на те, що вони не керують процесом напряму: з усіх п'яти вразливостей ця має найвищу часову оцінку (9,4).

Обмеження CVSS. CVSS оцінює серйозність, а не ризик. Він не враховує наслідків для безпеки людей і довкілля, які для OKI можуть бути головними (частково це виправлено в CVSS v4.0 додатковою метрикою Safety), і не враховує ймовірності експлуатації. Розбіжність оцінок NVD (7,8) і Siemens (9,3) для CVE-2022-38465 показує також, що базова оцінка залежить від трактування області впливу (Scope). У зведеній табл. 5.1 використано вектор NVD з незмінною областю (S:U), для якого середовищна оцінка становить 7,0, а після заходів 6,0 (Medium). Якщо ж область вважати зміненою, як у Siemens (S:C) або додавши MS:C до вектора NVD, середовищна оцінка зростає до 8,4 чи 7,9 відповідно, а після заходів в обох випадках дорівнює 7,5 (High). Тобто залежно від трактування Scope оцінка після заходів коливається від Medium (6,0) до High (7,5), і цю чутливість треба враховувати. Загалом CVSS слід поєднувати з каталогом CISA KEV, моделлю EPSS та аналізом наслідків для технологічного процесу.

Ефект заходів. Компенсуючі заходи знижують оцінки на 0,3…1,1 бала, але жодна з критичних вразливостей не опускається нижче High. Сегментація зменшує ймовірність атаки, проте не усуває вразливість. Тому заходи захисту периметра не можуть замінити оновлення прошивок, а лише дають час на їх планове встановлення.

7 Рекомендації

1. **Інвентаризація і SBOM.** Скласти перелік усіх кінцевих пристроїв IIoT з версіями прошивок і вимагати від постачальників перелік компонентів (SBOM). Без цього неможливо виявити вразливості на кшталт Ripple20, прихованих у сторонніх бібліотеках.
2. **Керування оновленнями.** Встановлювати оновлення прошивок (Treck 6.0.1.66 або вище, оновлення Hikvision, оновлені прошивки S7-1200/1500 разом із новою версією TIA Portal, оновлений BLE-компонент Cypress) у вікна обслуговування, попередньо перевіривши їх на тестовому стенді. Пріоритет визначати за середовищною оцінкою і

наявністю в каталозі KEV.

3. **Сегментація за IEC 62443.** Розділити мережу на зони і канали: окремі сегменти для ПЛК, для відеоспостереження та для корпоративної мережі; DMZ між IT і OT; жодного прямого доступу з інтернету (зокрема прибрати переадресацію портів до камер).
4. **Захист від DoS.** Обмежувати швидкість трафіку (rate limiting) до ПЛК на комутаторах і міжмережевих екранах, використовувати промислові міжмережеві екрани з глибоким аналізом протоколів, резервувати критичні контури керування.
5. **Захист ключів і доступу.** Змінити паролі доступу до ПЛК після оновлення, обмежити доступ до інженерних станцій (MFA, jump-сервер, журналювання сесій), фізично захистити шафи з ПЛК.
6. **Моніторинг.** Розгорнути сенсори виявлення аномалій OT-трафіку (пасивний аналіз Modbus, S7comm, PROFINET), відстежувати сплески трафіку і нетипові HTTP-запити до камер, контролювати BLE-ефір у критичних зонах.
7. **Закупівлі.** Включати у вимоги до постачальників підтримку оновлень, підписані прошивки, відсутність глобальних ключів і відповідність IEC 62443-4-2.

8 Відповіді на контрольні питання

1. Які покращення внесено в CVSS 3.1 порівняно з CVSS 3.0? Версія 3.1 (2019) не додала нових метрик, а уточнила стандарт. Функцію Roundup перевизначено так, щоб уникнути похибок обчислень із плаваючою комою. Формулу модифікованого впливу при зміненій області впливу виправлено ($MISS \cdot 0{,}9731$, показник степеня 13), щоб середовищна оцінка не перевищувала базову без підстав. Перероблено визначення Scope через поняття «органу безпеки» (security authority) і уточнено визначення PR, UI та інших метрик. Окремо наголошено, що CVSS вимірює серйозність, а не ризик. Додано рекомендації щодо використання часових і середовищних метрик та офіційний механізм розширень CVSS Extensions Framework.

2. Які види атак є найбільш небезпечними для ОКІ? Атаки, що порушують цілісність і доступність технологічного процесу: віддалене виконання коду на ПЛК і пристроях IIoT, несанкціонована зміна логіки або уставок контролерів (Stuxnet, Triton), цільові APT-атаки з руйнівним навантаженням (Industroyer, BlackEnergy), вимагачі та вайпери, DoS на компоненти керування, а також атаки через ланцюжок постачання та віддалений доступ підрядників.

3. Які підходи до визначення критичності вразливостей пропонує CVSS? Три групи метрик: базові (властивості самої вразливості), часові (стан експлойтів і виправлень) та середовищні (важливість активу для конкретної організації та наявні засоби захисту). Результат подається числом 0…10, якісною оцінкою (None, Low, Medium, High, Critical) і рядком-вектором, який дозволяє відтворити оцінку. Базову оцінку зазвичай надає виробник або NVD, а часову і середовищну має обчислювати сама організація.

4. Концепція Industry 4.0. Industry 4.0 означає четверту промислову революцію: об’єднання виробничого обладнання з цифровими технологіями в кіберфізичні системи. Її

складові: IIoT, хмарні та граничні обчислення, аналіз великих даних, штучний інтелект, цифрові двійники, адитивне виробництво, горизонтальна (по ланцюжку постачання) і вертикальна (від датчика до ERP) інтеграція. Наслідок для безпеки: зближення IT і OT, тож пристрої, які раніше були ізольованими, стають досяжними з мережі. Саме тому вразливості прошивок кінцевих пристроїв, розглянуті в цій роботі, стали загрозою для OKI.

9 Висновки

Для варіанта 4 обчислено оцінки CVSS v3.1 п’яти реальних вразливостей ПЗ і прошивок пристроїв IIoT для умовного водоканалу; власний калькулятор і офіційний калькулятор FIRST дали однакові результати, а базові оцінки збіглися з NVD. Головний практичний висновок: для OKI ранжувати вразливості лише за базовою оцінкою хибно, бо середовищні метрики змінюють пріоритети (DoS ПЛК піднявся з 7,5 до 9,1 через найвищу вимогу до доступності), а самі лише компенсуючі заходи не замінюють оновлення прошивок. Звідси й пріоритет заходів: інвентаризація та SBOM, оновлення за середовищною оцінкою і каталогом KEV, сегментація за IEC 62443.

10 Перелік джерел

1. FIRST. Common Vulnerability Scoring System v3.1: Specification Document. Revision 1. 2019. URL: https://www.first.org/cvss/v3.1/specification-document
2. FIRST. CVSS v3.1 Calculator. URL: https://www.first.org/cvss/calculator/3.1
3. JSOF. Ripple20: 19 Zero-Day Vulnerabilities Amplified by the Supply Chain. 2020. URL: https://www.jsof-tech.com/disclosures/ripple20/
4. Siemens ProductCERT. SSA-568427: Vulnerability in SIMATIC S7-1200 and S7-1500 CPU families. 2022. URL: https://cert-portal.siemens.com/productcert/pdf/ssa-568427.pdf
5. Garbelini M. E., Wang C., Chattopadhyay S. et al. SweynTooth: Unleashing Mayhem over Bluetooth Low Energy. USENIX ATC 2020. URL: https://asset-group.github.io/disclosures/sweyntooth/
6. NIST. National Vulnerability Database: CVE-2020-11896, CVE-2021-36260, CVE-2022-38465, CVE-2019-10953, CVE-2019-16336. URL: https://nvd.nist.gov/
7. CISA. Known Exploited Vulnerabilities Catalog. URL: https://www.cisa.gov/known-exploited-vulnerabilities-catalog
8. CISA. ICSA-19-106-03: Programmable Logic Controllers (Update A). URL: https://www.cisa.gov/news events/ics-advisories/icsa-19-106-03
9. Hikvision. Security Notification: Command Injection Vulnerability in Some Hikvision Products. 2021. URL: https://www.hikvision.com/en/support/cybersecurity/
10. Стьопочкіна І. В., Ільїн К. І., Овчарук М. В. Кіберзахист об’єктів критичної інфраструктури. Лабораторний практикум : навч. посіб. Київ : КПІ ім. Ігоря Сікорського, 2023. 59 с.

Додаток А. Калькулятор CVSS 3.1 (`cvss31.py`)

```
"""Калькулятор CVSS v3.1 за специфікацією FIRST розділ( 7 і додаток A).Рахує

 базову, часову та середовищну оцінки з рядкавектора-:

    >>> score("CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H")["base"]
    9.8
"""
from __future__ import annotations

import math

AV = {"N": 0.85, "A": 0.62, "L": 0.55, "P": 0.2}
AC = {"L": 0.77, "H": 0.44}
PR_U = {"N": 0.85, "L": 0.62, "H": 0.27}
PR_C = {"N": 0.85, "L": 0.68, "H": 0.5}
UI = {"N": 0.85, "R": 0.62}
CIA = {"H": 0.56, "L": 0.22, "N": 0.0}
E = {"X": 1.0, "H": 1.0, "F": 0.97, "P": 0.94, "U": 0.91}
RL = {"X": 1.0, "U": 1.0, "W": 0.97, "T": 0.96, "O": 0.95}
RC = {"X": 1.0, "C": 1.0, "R": 0.96, "U": 0.92}
REQ = {"X": 1.0, "H": 1.5, "M": 1.0, "L": 0.5}

BASE_KEYS = ("AV", "AC", "PR", "UI", "S", "C", "I", "A")


def roundup(x: float) -> float:
    """Округлення вгору до 0,1 без похибок плаваючої коми додаток( A)."""
    i = round(x * 100000)
    if i % 10000 == 0:
        return i / 100000.0
    return (math.floor(i / 10000) + 1) / 10.0


def severity(s: float) -> str:
    if s == 0:
        return "None"
    if s < 4.0:
        return "Low"
    if s < 7.0:
        return "Medium"
    if s < 9.0:
        return "High"
    return "Critical"


def parse(vector: str) -> dict[str, str]:
    parts = vector.split("/")
```

```
    if parts[0] != "CVSS:3.1":
        raise ValueError("очікується префікс CVSS:3.1")
    m = dict(p.split(":") for p in parts[1:])
    missing = [k for k in BASE_KEYS if k not in m]
    if missing:
        raise ValueError(f"бракує базових метрик: {missing}")
    return m


def score(vector: str) -> dict[str, float | str]:
    m = parse(vector)
    g = lambda k, d="X": m.get(k, d)  # noqa: E731

    # ---- base ----
    changed = m["S"] == "C"
    iss = 1 - (1 - CIA[m["C"]]) * (1 - CIA[m["I"]]) * (1 - CIA[m["A"]])
    impact = 7.52 * (iss - 0.029) - 3.25 * (iss - 0.02) ** 15 if changed else 6.42 * iss
    pr = (PR_C if changed else PR_U)[m["PR"]]
    expl = 8.22 * AV[m["AV"]] * AC[m["AC"]] * pr * UI[m["UI"]]
    if impact <= 0:
        base = 0.0
    elif changed:
        base = roundup(min(1.08 * (impact + expl), 10))
    else:
        base = roundup(min(impact + expl, 10))

    # ---- temporal ----
    t_mult = E[g("E")] * RL[g("RL")] * RC[g("RC")]
    temporal = roundup(base * t_mult)

    # ---- environmental ----
    mod = lambda k: m[k] if g("M" + k) == "X" else m["M" + k]  # noqa: E731
    ms_changed = mod("S") == "C"
    miss = min(
        1
        - (1 - REQ[g("CR")] * CIA[mod("C")])
        * (1 - REQ[g("IR")] * CIA[mod("I")])
        * (1 - REQ[g("AR")] * CIA[mod("A")]),
        0.915,
    )
    if ms_changed:
        m_impact = 7.52 * (miss - 0.029) - 3.25 * (miss * 0.9731 - 0.02) ** 13
    else:
        m_impact = 6.42 * miss
    mpr = (PR_C if ms_changed else PR_U)[mod("PR")]
    m_expl = 8.22 * AV[mod("AV")] * AC[mod("AC")] * mpr * UI[mod("UI")]
    if m_impact <= 0:
        env = 0.0
    elif ms_changed:
```

```
        env = roundup(roundup(min(1.08 * (m_impact + m_expl), 10)) * t_mult)
    else:
        env = roundup(roundup(min(m_impact + m_expl, 10)) * t_mult)

    return {
        "base": base,
        "temporal": temporal,
        "environmental": env,
        "impact": round(impact, 2),
        "exploitability": round(expl, 2),
    }


if __name__ == "__main__":
    import doctest

    doctest.testmod(verbose=False)
    # Приклади зі специфікації FIRST «CVSS v3.1 Examples»
    for v, want in [
        ("CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H", 9.8),
        ("CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H", 10.0),
        ("CVSS:3.1/AV:N/AC:H/PR:L/UI:R/S:C/C:L/I:L/A:N", 4.4),  # приклад із методички,
    ↪ звірено з калькулятором FIRST
        ("CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N", 6.1),  # XSS, phpMyAdmin
        ("CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H", 7.8),
    ]:
        got = score(v)["base"]
        assert got == want, (v, got, want)
    print("ok")
```

Додаток Б. Розрахунки та побудова (`solution.py`)

```
"""ЛР2, варіант 4: експлуатація вразливостей ПЗ і прошивок кінцевих пристроїв IIoT.Для

 пяти' реальних CVE рахується CVSS v3.1: базова оцінка вектор( NVD), часовазріліcть
( експлойта, наявність виправлення) і середовищна для умовного ОКІ,міського
 водоканалу, у двох станах: як« є» і після компенсуючих заходів.

    ../../.venv/bin/python solution.py            # розрахунки й графік
    ../../.venv/bin/python solution.py --first    # + знімки й звірка з калькулятором FIRST
"""
from __future__ import annotations

import json
import re
import subprocess
import sys
from pathlib import Path

import matplotlib

matplotlib.use("Agg")
import matplotlib.pyplot as plt
import numpy as np

from cvss31 import score, severity

HERE = Path(__file__).resolve().parent
ASSETS = HERE / "assets"
DATA = HERE / "data"
FIRST_URL = "https://www.first.org/cvss/calculator/3.1#"

# base: первинний вектор NVD; temporal: E/RL/RC; env_now: вимоги CR/IR/AR активу;
# env_after: модифіковані метрики після компенсуючих заходів поки( патч не встановлено).
CASES = [
    {
        "id": "CVE-2020-11896",
        "short": "Ripple20, стек Treck",
        "asset": "мережеві карти ДБЖ, шлюзи RS-485/Ethernet",
        "base": "AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H",
        "temporal": "E:P/RL:O/RC:C",
        "env_now": "CR:L/IR:H/AR:H",
        "env_after": "MAV:A",
    },
    {
        "id": "CVE-2021-36260",
        "short": "Hikvision, інєкція' команд",
        "asset": "IPкамери- охорони периметра",
        "base": "AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H",
```

```
        "temporal": "E:H/RL:O/RC:C",
        "env_now": "CR:H/IR:M/AR:M",
        "env_after": "MAV:A",
    },
    {
        "id": "CVE-2022-38465",
        "short": "SIMATIC S7-1200/1500, ключ",
        "asset": "ПЛК керування насосами",
        "base": "AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H",
        "temporal": "E:P/RL:O/RC:C",
        "env_now": "CR:H/IR:H/AR:H",
        "env_after": "MPR:H",
    },
    {
        "id": "CVE-2019-10953",
        "short": "ПЛК, DoSфлуд-",
        "asset": "ПЛК (ABB, Phoenix, Schneider, Siemens, WAGO)",
        "base": "AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H",
        "temporal": "E:H/RL:W/RC:C",
        "env_now": "CR:L/IR:M/AR:H",
        "env_after": "MAV:A",
    },
    {
        "id": "CVE-2019-16336",
        "short": "SweynTooth, BLE PSoC 4",
        "asset": "бездротові BLEдатчики- тиску й рівня",
        "base": "AV:A/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H",
        "temporal": "E:F/RL:O/RC:C",
        "env_now": "CR:L/IR:L/AR:M",
        "env_after": "MAC:H",
    },
]


def vectors(c: dict) -> dict[str, str]:
    b = "CVSS:3.1/" + c["base"]
    t = f"{b}/{c['temporal']}"
    now = f"{t}/{c['env_now']}"
    after = f"{now}/{c['env_after']}"
    return {"base": b, "temporal": t, "env_now": now, "env_after": after}


def nvd_record(cve: str) -> dict:
    d = json.loads((DATA / f"{cve}.json").read_text())
    v = d["vulnerabilities"][0]["cve"]
    metrics = v["metrics"]["cvssMetricV31"]
    return {
        "published": v["published"][:10],
        "kev": bool(v.get("cisaExploitAdd")),
```

```
        "cwe": sorted({w["description"][0]["value"] for w in v.get("weaknesses", [])}),
        "metrics": [(m["source"], m["type"], m["cvssData"]["vectorString"],
                     m["cvssData"]["baseScore"]) for m in metrics],
    }


def first_scores(vector: str) -> dict[str, float]:
    """Оцінки, які показує офіційний калькулятор FIRST для цього вектора."""
    dom = subprocess.run(
        ["chromium", "--headless=new", "--no-sandbox", "--disable-gpu",
         "--virtual-time-budget=15000", "--dump-dom", FIRST_URL + vector],
        capture_output=True, text=True, timeout=90).stdout
    out = {}
    for k in ("base", "temporal", "environmental"):
        m = re.search(rf'id="{k}MetricScore">([\d.]+)<', dom)
        out[k] = float(m.group(1)) if m else float("nan")
    return out


def first_screenshot(vector: str, png: Path) -> None:
    from PIL import Image

    raw = png.with_suffix(".raw.png")
    subprocess.run(
        ["chromium", "--headless=new", "--no-sandbox", "--disable-gpu", "--hide-scrollbars",
         "--window-size=1280,1600", "--virtual-time-budget=15000",
         f"--screenshot={raw}", FIRST_URL + vector],
        capture_output=True, timeout=90, check=True)
    # базові метрики, рядоквектор-, часові метрики й заголовок середовищної оцінки
    im = Image.open(raw)
    top = im.crop((250, 375, 1270, 1290))
    env = im.crop((250, 1336, 1270, 1397))
    out = Image.new("RGB", (top.width, top.height + env.height), "white")
    out.paste(top, (0, 0))
    out.paste(env, (0, top.height))
    out.save(png)
    raw.unlink()


def main() -> None:
    with_first = "--first" in sys.argv
    rows = []
    for c in CASES:
        v = vectors(c)
        s_b = score(v["base"])
        s_now = score(v["env_now"])
        s_after = score(v["env_after"])
        nvd = nvd_record(c["id"])
        primary = next(m for m in nvd["metrics"] if m[1] == "Primary")
```

```
    assert primary[2] == v["base"], (c["id"], primary[2])
    assert primary[3] == s_b["base"], (c["id"], primary[3], s_b["base"])
    row = {
        **c,
        "vectors": v,
        "nvd": nvd,
        "impact": s_b["impact"],
        "exploitability": s_b["exploitability"],
        "base": s_b["base"],
        "temporal": s_now["temporal"],
        "env_now": s_now["environmental"],
        "env_after": s_after["environmental"],
        "sev_base": severity(s_b["base"]),
        "sev_now": severity(s_now["environmental"]),
        "sev_after": severity(s_after["environmental"]),
    }
    if with_first:
        f_now, f_after = first_scores(v["env_now"]), first_scores(v["env_after"])
        row["first"] = {"env_now": f_now, "env_after": f_after}
        assert f_now == {"base": row["base"], "temporal": row["temporal"],
                         "environmental": row["env_now"]}, (c["id"], f_now)
        assert f_after["environmental"] == row["env_after"], (c["id"], f_after)
        first_screenshot(v["env_now"], ASSETS / f"first-{c['id']}.png")
    rows.append(row)

# Інші оцінки тих самих CVE вендор( як CNA), якщо відрізняються від NVD
for r in rows:
    for src, typ, vec, sc in r["nvd"]["metrics"]:
        if typ == "Secondary" and vec != r["vectors"]["base"]:
            r["alt"] = {"source": src, "vector": vec, "score": sc}

# ---- аналіз чутливості ----
# 1) CVE-2022-38465 за трактуванням Siemens (PR:N, S:C) та за NVD з MS:C:
#    один« витягнутий ключ компрометує весь парк ПЛК».
v36260 = next(r for r in rows if r["id"] == "CVE-2022-38465")
siemens = "AV:L/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H/E:P/RL:O/RC:C"
v36260["sensitivity"] = {
    "siemens_vector": {
        "vector": "CVSS:3.1/" + siemens,
        "base": score("CVSS:3.1/" + siemens)["base"],
        "env_now": score(f"CVSS:3.1/{siemens}/CR:H/IR:H/AR:H")["environmental"],
        "env_after": score(f"CVSS:3.1/{siemens}/CR:H/IR:H/AR:H/MPR:H")["environmental"],
    },
    "nvd_msc": {
        "vector": f"{v36260['vectors']['env_now']}/MS:C",
        "env_now": score(f"{v36260['vectors']['env_now']}/MS:C")["environmental"],
        "env_after": score(f"{v36260['vectors']['env_now']}/MS:C/MPR:H")["environmental"],
    },
}
```

```
# 2) CVE-2019-10953: наскільки висока вимога до доступності (AR)
#    підіймає оцінку; AR:M замість AR:H.
v10953 = next(r for r in rows if r["id"] == "CVE-2019-10953")
v10953["sensitivity"] = {
    "arm": {
        "vector": v10953['vectors']['env_now'].replace("AR:H", "AR:M"),
        "env_arm": score(f"{v10953['vectors']['temporal']}/CR:L/IR:M/AR:M")["environmental
↪ "],
        "env_arh": v10953["env_now"],
    }
}

DATA.mkdir(exist_ok=True)
(DATA / "results.json").write_text(json.dumps(rows, ensure_ascii=False, indent=2))

# ---- графік ----
plt.rcParams.update({"font.family": "Liberation Serif", "font.size": 11})
fig, ax = plt.subplots(figsize=(9, 4.6))
labels = [f"{r['id']}\n{r['short']}" for r in rows]
series = [("Базова", "base", "#1f4e79"), ("Часова", "temporal", "#5b8db8"),
          ("Середовищна, як є", "env_now", "#c0392b"),
          ("Після заходів", "env_after", "#27ae60")]
xs = np.arange(len(rows))
w = 0.2
for k, (name, key, col) in enumerate(series):
    vals = [r[key] for r in rows]
    bars = ax.bar(xs + (k - 1.5) * w, vals, w, label=name, color=col)
    ax.bar_label(bars, fmt="%.1f", fontsize=8, padding=1)
for lo, hi, col in [(0, 4, "#eafaf1"), (4, 7, "#fef9e7"), (7, 9, "#fdf2e9"), (9, 10.6, "#
↪ fdedec")]:
    ax.axhspan(lo, hi, color=col, zorder=0)
for y0, name in [(2, "Low"), (5.5, "Medium"), (8, "High"), (9.6, "Critical")]:
    ax.text(len(rows) - 0.45, y0, name, ha="right", va="center", fontsize=8, color="grey")
ax.set_xticks(xs, labels, fontsize=8.5)
ax.set_ylim(0, 10.6)
ax.set_ylabel("Оцінка CVSS v3.1")
ax.legend(ncol=4, loc="upper center", bbox_to_anchor=(0.5, -0.2), frameon=False)
fig.tight_layout()
ASSETS.mkdir(exist_ok=True)
fig.savefig(ASSETS / "01-scores.png", dpi=200)

for r in rows:
    print(f"{r['id']}  base {r['base']:4} ({r['sev_base']:8}) temporal {r['temporal']:4} "
          f"env {r['env_now']:4} ({r['sev_now']:8}) after {r['env_after']:4} ({r['
↪ sev_after']})"
          + ("  FIRST ok" if "first" in r else ""))
    print("   ", r["vectors"]["env_after"])
```

```
if __name__ == "__main__":
    main()
```